Sandrine Hardy

Concevoir et piloter la gouvernance des données

Projet Spotify

Certification Architecte en Intelligence Artificielle

SPOTIFY
MISE EN PLACE D'UNE POLITIQUE DE GOUVERNANCE DES DONNÉES

TABLE DES MATIÈRES

1. Politique de gouvernance des données.....3
1.1 Objectifs et périmètre.....3
1.2 Principes directeurs.....3
1.3 Qualité, traçabilité et sécurité.....3
1.4 Conformité : RGPD et réglementations locales.....4
1.5 Formation et pilotage.....4
1.6 Instances de gouvernance.....5
1.7 Matrice RACI des responsabilités.....5
2. Organigramme, rôles et responsabilités.....6

1. Politique de gouvernance des données

1.1 Objectifs et périmètre

Objectif : disposer d'une politique de gouvernance robuste, adaptée à Spotify : données fiables, sécurisées, conformes (RGPD, réglementations locales, PCI-DSS, AI Act) et partagées entre équipes. Périmètre : toutes les données personnelles, de paiement, de contenu et les modèles d'IA, tous les systèmes qui les traitent, tous les collaborateurs et prestataires, dans tous les pays. Le RGPD sert de référence en Europe ; les réglementations locales des autres pays s'y ajoutent, suivies par la veille.

Sigles : RGPD (règlement général sur la protection des données, européen) ; PCI-DSS (norme de sécurité des cartes de paiement) ; AI Act (règlement européen sur l'intelligence artificielle).

1.2 Principes directeurs

Principe	Règle opérationnelle	Indicateur
1. Responsabilité	Chaque jeu de données critique a un Data Owner et un Data Steward nommés, inscrits au catalogue.	% de jeux critiques avec owner
2. Transparence	Traitements documentés (registre), avis de confidentialité clairs, origine des données tracée.	% de traitements au registre
3. Sécurité	Sécurité dès la conception : chiffrement, accès limité au nécessaire, traces conservées, réponse aux incidents.	Incidents ; délai de notification
4. Qualité	Seuils définis pour les données critiques ; contrôles automatiques et audits réguliers.	Complétude, unicité, actualisation (freshness)
5. Conformité	Exigences réglementaires intégrées aux processus et aux outils ; revue juridique périodique.	Nombre d'écarts d'audit
6. Minimisation	Collecte limitée au nécessaire pour une finalité déclarée ; durées de conservation fixées.	Champs collectés vs nécessaires
7. Droits des utilisateurs	Accès, rectification, suppression, portabilité, opposition : parcours simple, délais tenus.	Délai de traitement ; accessibilité des formulaires de demande
8. Amélioration continue	Revue trimestrielle des indicateurs, audit annuel, politique mise à jour à chaque évolution majeure.	Plan d'actions
9. Éthique d'usage	Systèmes d'IA inventoriés, testés contre les biais, explicables et supervisés.	% de modèles documentés

Sigles : Data Owner (responsable des données d'un domaine métier) ; Data Steward (garant de leur qualité au quotidien).

1.3 Qualité, traçabilité et sécurité

- Qualité : cibles de départ, à ajuster pendant le pilote : au moins 95 % de champs renseignés, au plus 1 % de doublons, 98 % d'exactitude sur des échantillons contrôlés, et une fréquence d'actualisation (freshness) fixée pour chaque jeu de données.
- Accords entre équipes et catalogue : chaque jeu de données partagé fait l'objet d'un accord écrit entre l'équipe qui le produit et celles qui l'utilisent (contenu, mise à jour, niveau de qualité, responsable). Un catalogue unique recense toutes les données et leur origine, ce qui permet de contrôler et de traiter une demande de suppression.
- Accès : chacun n'accède qu'aux données utiles à sa mission (selon son métier, l'objectif de l'analyse et le pays). Par défaut, les analyses se font sur des données dont l'identité est masquée ou regroupées ; les données de carte de paiement sont confiées à un prestataire certifié.

Niveau	Exemples	Règles minimales
Public	Catalogue public, communiqués	Aucune restriction
Interne	Métadonnées de contenu, indicateurs agrégés	Accès des employés ; traces conservées
Confidentiel	Données personnelles d'usage, segments marketing	Accès limité aux personnes autorisées ; chiffrement ; identité masquée par défaut
Restreint	Données de paiement, données sensibles	Accès nominatif et justifié ; chiffrement fort ; revue trimestrielle

1.4 Conformité : RGPD et réglementations locales

Checklist de conformité : statuts estimés à partir du business case (hypothèses à confirmer lors de l'audit initial).

Texte	Exigence	Statut	Mesure de gouvernance	Pilote
RGPD	Traitement licite, loyal et transparent	Partiel	Registre des traitements, avis de confidentialité	DPO
RGPD	Consentement explicite et éclairé	Partiel	Consentement centralisé, traçable, révocable	DPO
RGPD	Droits d'accès, de rectification, de suppression	Partiel	Parcours unique, délai cible 15 jours (légal : 1 mois)	DPO
RGPD	Notification des violations sous 72 h	À vérifier	Procédure testée, exercice annuel	DPO
RGPD	DPO désigné et indépendant	Oui	Garantir indépendance et moyens du DPO	CDO
RGPD	Transferts hors Union européenne encadrés	À vérifier	Clauses contractuelles, cartographie des flux	DPO
Local	Droits des personnes, refus de la vente ou du partage des données, non-discrimination selon la loi de chaque pays	À vérifier	Même parcours que le RGPD ; veille et audit pays par pays	DPO
PCI-DSS	Protection des données de carte, accès, tests	À vérifier	Tokenisation, chiffrement, revues, tests d'intrusion	CISO

- AI Act : inventaire des systèmes d'IA (recommandation, personnalisation), classification par niveau de risque, information de l'utilisateur, explication de « pourquoi cette recommandation », tests de biais (diversité, artistes émergents) avant mise en production, fiche de chaque modèle.

Sigles : DPO (Data Protection Officer, délégué à la protection des données) ; CDO (Chief Data Officer, directeur des données) ; CISO (responsable de la sécurité des systèmes d'information).

1.5 Formation et pilotage

- Formation par public : tous (RGPD, sécurité : formation en ligne à l'arrivée puis chaque année), Owners et Stewards (ateliers, communauté mensuelle), ingénieurs et analystes de données (protection des données dès la conception, biais), Marketing et support (consentement, droits). Supports accessibles à tous, vidéos sous-titrées.
- Audits et veille : audit interne trimestriel par l'équipe de gouvernance (séparée du data management), audit externe annuel ; le DPO et le Juridique suivent la réglementation, le CoE les technologies ; politique révisée au moins une fois par an.

Axe	Indicateur	Cible à 24 mois	Fréquence
Qualité	Complétude des données critiques / doublons	≥ 95 % / ≤ 1 %	Mensuelle
Gouvernance	Jeux critiques catalogués avec owner et steward	100 %	Trimestrielle
Conformité	Demandes de droits traitées dans le délai cible / violations notifiées sous 72 h	≥ 95 % / 100 %	Mensuelle
Sécurité et IA	Accès critiques revus ; modèles en production documentés	100 %	Trimestrielle
Efficacité, culture	Délai d'accès à une donnée autorisée ; collaborateurs formés	− 50 % ; ≥ 95 %	Trimestrielle

Sigles : CoE (Centre d'Excellence : équipe centrale qui regroupe le responsable de la gouvernance et les Data Stewards, définit les standards et appuie les domaines métier).

1.6 Instances de gouvernance

Instance	Fréquence	Participants	Objet
Comité de gouvernance	Mensuelle	CDO (président), DPO, CTO / CISO, Juridique, Data Owners	Valider politiques et exceptions, suivre les indicateurs et les risques, arbitrer entre domaines
Communauté des Stewards	Mensuelle	Responsable DG, Data Stewards, Data Engineering	Partager les pratiques, suivre la qualité, traiter les anomalies
Comité conformité et risques	Trimestrielle	DPO, CISO, Juridique, CDO	Audit, incidents, veille réglementaire
Revue IA responsable	À chaque mise en production	Équipe du modèle, CoE, DPO	Valider biais, transparence, documentation du modèle

1.7 Matrice RACI des responsabilités

Matrice RACI (R réalise, A répond du résultat : un seul par ligne, C consulté, I informé).

Activité	CDO	DPO	DG (CoE)	Owner	Steward	Data Eng.	CISO	Jur.
Définir et mettre à jour la politique	A	C	R	C	I	I	C	C
Tenir le catalogue et le glossaire	I	I	A	C	R	R	–	–
Mesurer et améliorer la qualité	I	–	C	A	R	R	–	–
Établir les accords entre équipes	I	–	C	A	R	R	–	–
Gérer les accès aux données	I	C	I	A	C	R	R	–
Registre des traitements	I	A	C	R	C	C	C	C
Consentement et droits des personnes	I	A	C	C	C	R	–	C
Gérer les violations (72 h)	I	A	I	C	I	R	R	C
Conformité PCI-DSS	I	C	I	R	C	R	A	C
Gouvernance de l'IA	A	C	R	C	C	R	C	C
Formation et sensibilisation	A	C	R	C	R	I	C	C
Audits et suivi des indicateurs	A	C	R	C	C	C	C	I
Veille réglementaire	I	A	C	I	I	C	C	R

Sigles : CTO (directeur technique) ; DG (Data Governance, gouvernance des données : le Responsable DG anime le CoE) ; Data Eng. ou Data Engineering (équipe qui construit et fait fonctionner le stockage et les flux de données) ; Jur. (Juridique) ; RACI (R : réalise, A : répond du résultat, C : consulté, I : informé).

2. ORGANIGRAMME, RÔLES ET RESPONSABILITÉS

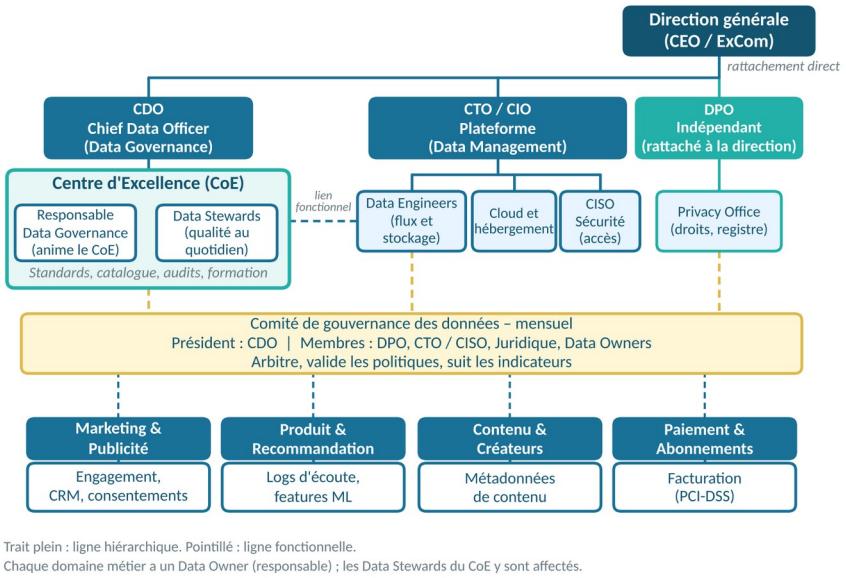


Figure 1 – Organisation cible de la gouvernance des données, avec le Centre d'Excellence

Sigles : CEO (directeur général) ; ExCom (comité exécutif) ; CIO (directeur des systèmes d'information) ; CDO (directeur des données) ; DPO (délégué à la protection des données) ; CTO (directeur technique) ; CISO (responsable de la sécurité) ; CoE (Centre d'Excellence) ; Data Governance (gouvernance des données) ; Data Management (gestion des données au quotidien).

Rôle	Responsabilités clés
CDO (Chief Data Officer)	Fixe la politique, préside le comité de gouvernance (mensuel), arbitre, rend compte à la direction
DPO (Data Protection Officer), indépendant	Conseille et contrôle la conformité, tient le registre, point de contact des autorités
Responsable Data Governance (CoE)	Standards, catalogue, audits, formation, pilotage des indicateurs, coordination des Stewards
Data Owner (par domaine)	Valide classification et accès, fixe les objectifs de qualité, accepte les risques
Data Steward (membre du CoE, affecté à un domaine)	Assure la qualité au quotidien : documente, corrige, traite les anomalies
Data Custodian (Data Engineers du CTO / CIO, reliés au CoE)	Opère pipelines et stockage, met en œuvre contrôles, accès et suivi de l'origine
CISO (sécurité) / Juridique	Sécurité, gestion des accès, PCI-DSS, réponse aux incidents / contrats, veille réglementaire

- Le CDO, rattaché à la direction générale, porte la donnée comme enjeu stratégique ; le DPO, rattaché directement à la direction, reste indépendant (le RGPD interdit tout conflit d'intérêts).
- La gouvernance (CDO : règles et contrôle) est séparée du data management (CTO / CIO : Data Engineers, infrastructure, sécurité). Le CoE regroupe les Stewards, affectés aux domaines où un Data Owner décide ; les Data Engineers y sont reliés (cible atteinte en deux temps : voir le plan).
- Le comité de gouvernance se réunit chaque mois (CDO, DPO, CTO / CISO, Juridique, Data Owners) ; un comité conformité et risques se réunit chaque trimestre.